

Relatorio de Auditoria de Seguranca

010-galeria-de-fotos

Data: 06 de setembro de 2026

Escopo: backend Quarkus, frontend React/Vite, persistencia PostgreSQL, scripts locais e configuracao externa.

Resultado: sem achados confirmados em aberto. A ausencia deliberada de autenticao no backend permanece uma limitacao aceita exclusivamente para demonstracao local.

Resumo executivo

Foram examinados os cinco endpoints da API, fluxos por identificador, validacoes de upload, renderizacao do frontend, persistencia, configuracoes e automacao local. Nao foram confirmados segredos em artefatos versionados da Change, injecao de consulta, execucao dinamica de codigo ou HTML cru.

Limitacao de seguranca

A API nao possui autenticao, autorizacao, usuario, tenant ou isolamento por proprietario. Qualquer cliente com acesso ao ambiente local pode listar, consultar, alterar ou excluir fotos. Essa condicao consta como fora de escopo na SPEC e impede uso em producao.

Pontos fortes

- Allowlist de JPEG, PNG, GIF e WebP.
- Rejeicao de arquivos vazios ou maiores que 5 MiB.
- Descricao limitada a 5.000 caracteres.
- Entidades JPA nao expostas pela API.
- JSX sem HTML cru ou eval.
- Configuracao selecionada por secao sem impressao de valores.
- BAT preenchido local e ignorado pelo Git.

Categorias avaliadas

Categoria	Conclusao
Autenticacao e autorizacao	Limitacao aceita para demonstracao local; inadequada para producao.
Tenant, usuario e IDOR	Nao aplicavel ao contrato atual, sem identidade ou propriedade; risco coberto pela limitacao acima.
Segredos	Conforme no estado atual: valores ficam no arquivo externo e no BAT local ignorado; evidencias usam dados sinteticos.
Entrada e upload	Conforme: allowlist de media type, limites de tamanho e nome-base do arquivo.
XSS e injecao	Nenhuma superficie exploravel confirmada na inspecao estatica.

Achados e recomendacoes

Nenhum achado de seguranca confirmado permanece em aberto nesta Change.

P1 - antes de qualquer publicacao

Criar uma Change especifica para autenticao e autorizacao no servidor, vinculando cada operacao ao contexto autenticado. Nao reutilizar o login estatico do navegador como controle de acesso.

P2 - endurecimento futuro

Validar a assinatura real dos bytes de imagem alem do media type declarado e considerar armazenamento de objetos fora do banco para reduzir impacto operacional de payloads Base64.

Metodologia e evidencias

A auditoria combinou busca estatica por segredos e APIs perigosas, leitura dos fluxos REST e Fetch, verificacao dos limites de entrada, revisao do gerador de configuracao e confirmacao de que o BAT preenchido e ignorado. Valores externos foram redigidos e nao integram este relatorio.

Comandos relacionados: mvn verify; npm test -- --run; npm run build; gerador com secao valida e secao ausente.